AI01 / FIELD CASE STUDY

AI-Assisted SOC Analyst

From Wazuh alerts to evidence-grounded cases, with analyst-controlled Azure AI analysis and a reproducible three-scenario evaluation.

39	3 / 3	3
Python tests passed	live scenarios passed	telemetry families

The problem

My SOC01 lab already produced Windows, Zeek and Suricata alerts. The hard part was turning those separate alerts into a defensible incident narrative while keeping source attribution, confidence and analyst ownership clear. A sensor seeing a packet is not necessarily the system affected by it; a detection label is not proof of malicious intent.

I built AI01 as a local analyst workspace that retrieves recent Wazuh evidence, normalizes host and network fields, groups related alerts, and saves investigation state. Azure AI is called only when I select Analyze. Its structured response includes facts, hypotheses, ATT&CK mapping, next steps and missing evidence.

Architecture and trust boundaries

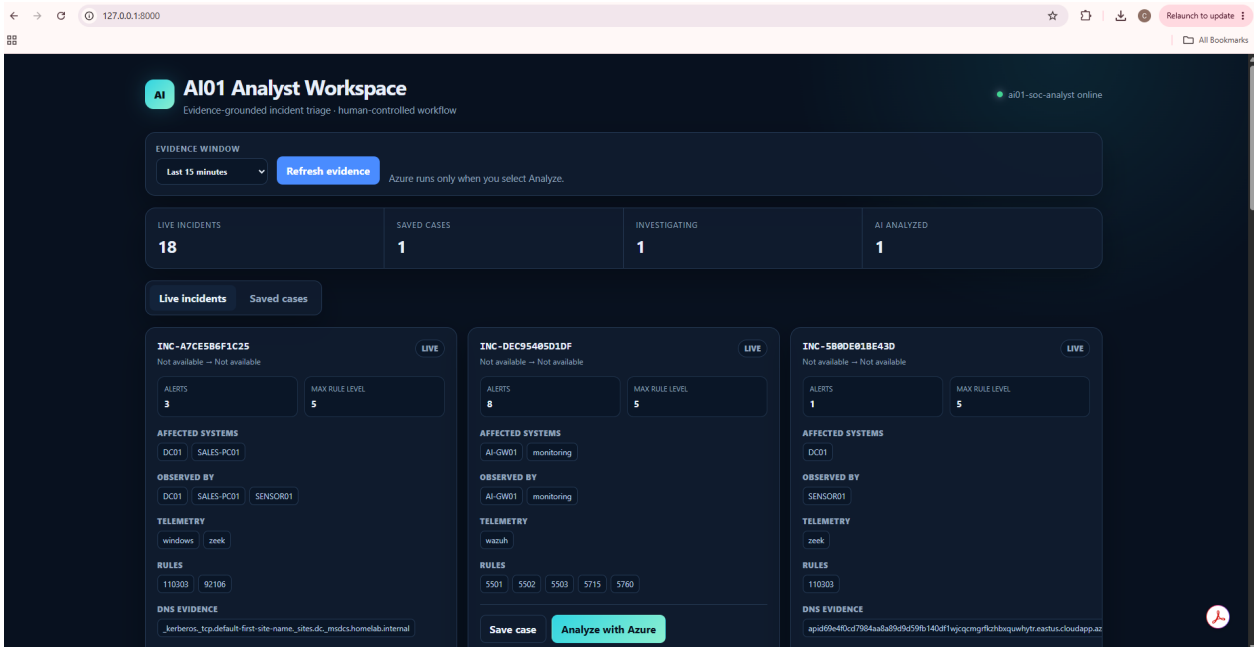
Windows endpoints / DC01 + SENSOR01 (Zeek, Suricata) → Wazuh manager and indexer → AI-GW01 read-only collector → normalization and asset inventory → deterministic correlation → incident workspace → optional Azure AI analysis → SQLite saved case.

The indexer connection uses HTTPS with pinned server SPKI; the collector runs bounded, source-balanced queries. AI-GW01 is deployed under a dedicated unprivileged **ai01** account, with its environment file outside the web root, private case database, systemd restart policy, health-check timer and loopback-only HTTP binding. Analysts reach the UI through the lab access path.

The pipeline preserves observer and affected-system fields separately. For example, a Zeek alert can be observed by SENSOR01 while the DNS client is SALES-PC01 or DC01. Asset enrichment supplies role, zone and criticality from a local inventory; it does not claim to prove endpoint ownership.

Workflow: from evidence to a case

1. Choose a bounded evidence window and review the live incidents. 2. Inspect alert count, rule IDs, IPs, DNS markers, affected systems and observers. 3. Save a case and set status and notes. 4. Request AI analysis for that selected incident. 5. Review the structured output and investigate its missing evidence before changing the case disposition.



Workspace view: live incidents, source-aware system labels, rules and evidence-window controls.

A saved case survives service restarts and host reboot. In the live Phase 5 check, the same investigating case and its attached AI result remained available after restart and reboot. The model output is stored as analyst-facing context, not an automatic case closure.

Problems solved in the build

Network telemetry parsing and identity

Zeek JSON uses dotted source and destination keys, so normalization had to translate the Wazuh/Filebeat shape into consistent network fields. DNS rule tuning distinguished a long query from a direct resolver bypass and a no-response observation. The asset map then attributed 10.20.20.168 to SALES-PC01 while retaining SENSOR01 as the observer.

Correlating related evidence without flattening it

The SMB scenario initially grouped a Windows System SMB-port alert without the expected Administrator user. I traced the indexed events, confirmed the successful privileged logon appeared separately, and added a narrow correlation between the FILE01 privileged logon rule and the nearby admin-share alert. The subsequent live run also included a Suricata NTLM session, so the analyst saw network and host evidence in one incident. A cached or delayed index result can change the apparent incident; each live evaluation was rerun after ingest settled.

Operating the app reliably

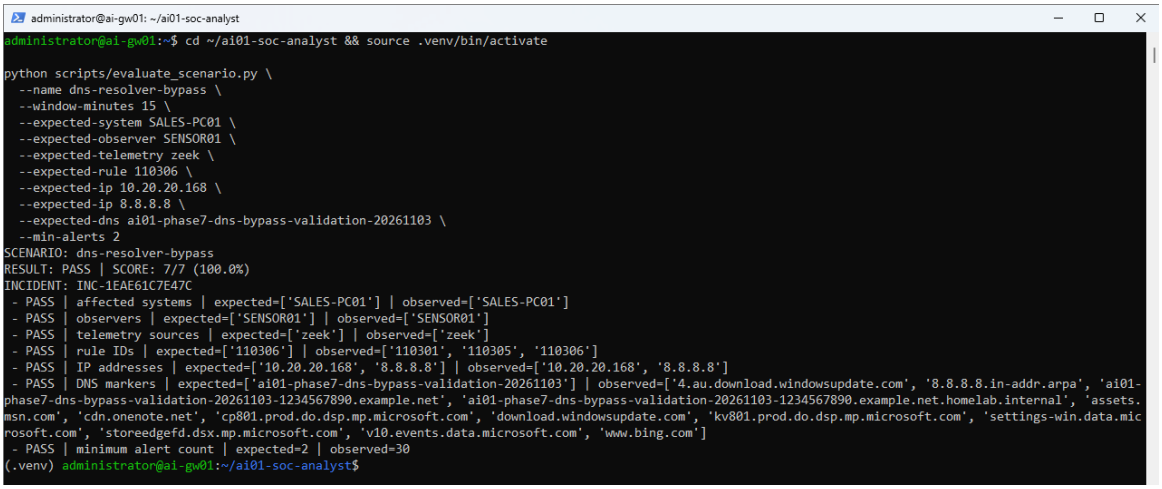
The first health-check timer fired before Uvicorn finished startup and returned connection refused. A later check passed. I verified restart after a killed service process, persistence across reboot, the dedicated service account, and that the production copy was synchronized with the reviewed source branch. The final deployment reported version 0.6.0 at the Phase 6 checkpoint; Phase 7 controlled evaluation followed on the merged 0.7.0 line.

Controlled evaluation: three observed outcomes

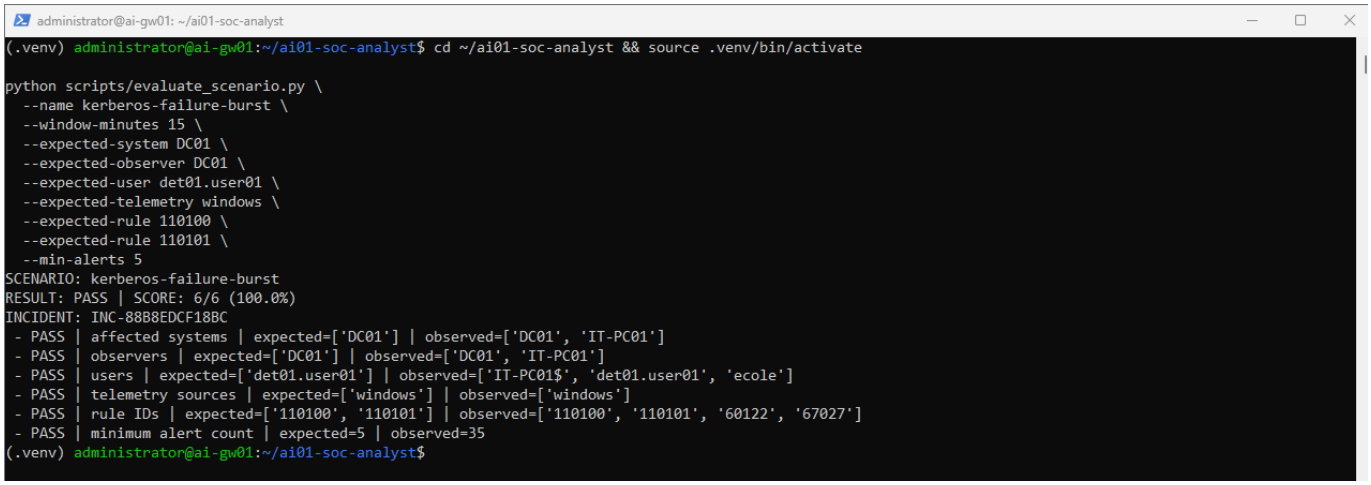
These are controlled homelab exercises, not evidence of real compromise. Each scenario generated live telemetry and was scored with the repository evaluator against expected systems, observers, users, rule IDs and minimum alert counts.

Scenario	Observed evidence	Score
Direct DNS bypass	SALES-PC01 → 8.8.8.8; Zeek; rule 110306	7 / 7
Kerberos failure burst	DC01; det01.user01; Windows rules 110100/110101	6 / 6
Authorized admin SMB	IT-PC01 → FILE01; Administrator; Windows/Suricata	6 / 6

The automated Python suite finished with **39 passed** after the final scenario work. The live checks validate those three scenarios in this lab and window; they do not establish general detection accuracy, false-positive rates or production readiness in other environments.

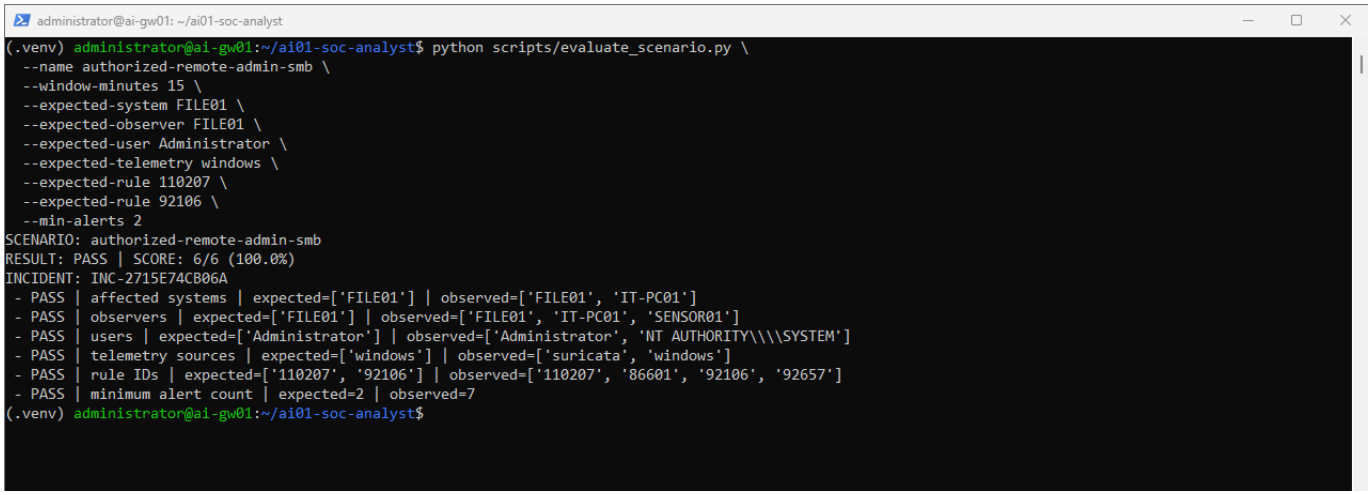


DNS scenario: direct resolver bypass detected and evaluated against the expected asset, observer and DNS marker.



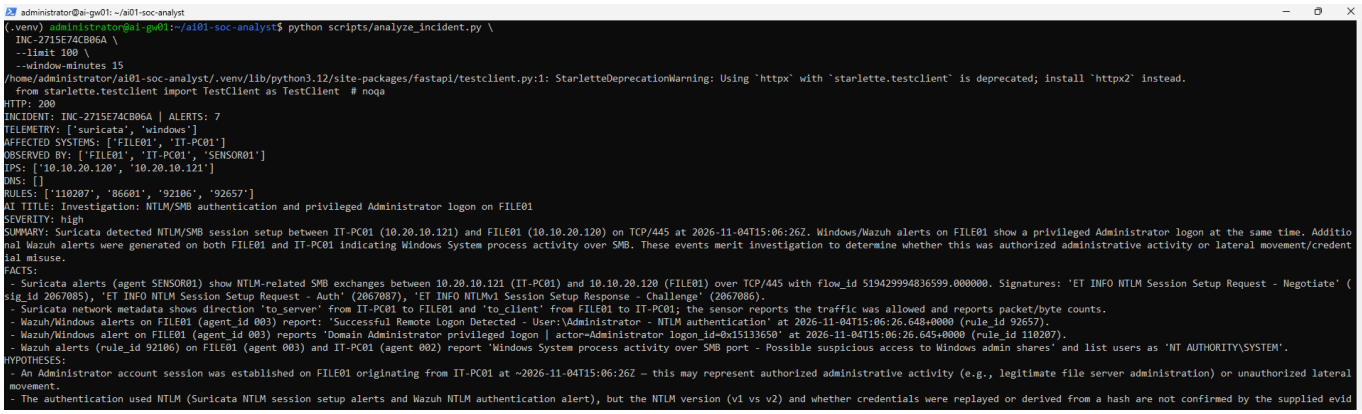
Kerberos scenario: a repeated failure burst linked to DC01 and the test user, scored 6/6.

SMB scenario: a useful distinction



Authorized remote admin SMB: the final controlled run scored 6/6 and retained Windows plus Suricata evidence.

From IT-PC01, I explicitly authenticated as HOMELAB\Administrator to FILE01 and listed the administrative C$ share. The Wazuh alert showed a successful privileged logon; Suricata showed an NTLM/SMB session. The case analyzer described the observed session and considered both authorized administration and lateral movement as possibilities.



AI analysis: observed NTLM/SMB and privileged logon are facts; pass-the-hash remains unproven.

The model correctly called out missing 4624/4648/4672 details, process attribution and packet evidence. It did **not** claim a pass-the-hash finding. The account and share access were authorized in this exercise; the technique mapping helps an analyst ask follow-up questions rather than certify an attack.

Lessons and remaining limits

Source provenance matters. A sensor name, source asset and affected system have different meanings. **Index latency matters.** Allow ingestion to settle and inspect raw events when scenario scoring changes. **Rule text is a lead.** “Possible” in a Wazuh rule does not establish an attacker technique. **AI is subordinate to evidence.** The analyst must check hypotheses, local policy and missing telemetry.

The lab has no general accuracy benchmark, no measured false-positive rate, and no proof that the SMB exercise used NTLMv1 or pass-the-hash. The final Proxmox snapshot is a separate operational step handled by the lab owner.